# IROP ΓÇö REST API Design Document

> **Version:** 1.0
> **Last Updated:** 2025-07-15
> **Base URL:** `http://localhost:4000`

## Table of Contents


1. Conventions
2. Authentication
3. Error Format
4. Mongoose Schemas
    - User
    - LeaveRequest
    - Asset
    - InventoryItem
5. API Endpoints
    - Health
    - Auth
    - Users
    - Leaves
    - Assets
    - Inventory


## Conventions

| Convention | Detail |
|---|---|
| **Transport** | JSON over HTTPS (HTTP in development) |
| **Auth mechanism** | Bearer JWT in `Authorization` header |
| **Pagination** | Query params `page` (1-based, default 1) and `limit` (default 20, max 100) |
| **Pagination response** | Every list endpoint returns `{ data: T[], pagination: { page, limit, total, pages } }` |
| **Dates** | ISO 8601 strings ( `YYYY-MM-DDTHH:mm:ss.sssZ` ) |
| **IDs** | MongoDB ObjectId strings (24-char hex) |
| **Soft-delete** | Not used ΓÇö documents are hard-deleted where deletion is supported |

## Authentication

All protected endpoints require the header:

```
Authorization: Bearer <jwt_token>
```

The JWT payload contains:

```
{   "sub": "<userId>",       // MongoDB ObjectId   "role": "employee",      // employee | manager | admin   "ia
```

Tokens are issued by `POST /api/auth/login` and verified by the `authenticate` middleware on every protected route.

## Error Format

All errors are returned with the appropriate HTTP status code and a consistent JSON body:

```
{   "error": {     "code": "VALIDATION_ERROR",     "message": "Human-readable description of what went wrong",
```

### Error Codes

| Code | HTTP Status | When Used |
|---|---|---|
| `VALIDATION_ERROR` | 400 | Request body / query fails schema validation |
| `UNAUTHORIZED` | 401 | Missing, expired, or invalid JWT |
| `FORBIDDEN` | 403 | Valid JWT but insufficient role / ownership |
| `NOT_FOUND` | 404 | Resource does not exist |
| `CONFLICT` | 409 | Duplicate key (e.g. email already exists) |
| `QUOTA_EXCEEDED` | 400 | Leave request exceeds available quota balance |
| `INTERNAL_ERROR` | 500 | Unhandled server error |

## Mongoose Schemas

### 1. User

**Collection:** `users`

| Field | Type | Constraints | Default | Notes |
|---|---|---|---|---|
| `_id` | `ObjectId` | auto | ΓÇö | Primary key |
| `name` | `String` | **required**, trimmed | ΓÇö | Full display name |
| `email` | `String` | **required**, **unique**, lowercase, trimmed, validated (regex) | ΓÇö | Login identifier |
| `passwordHash` | `String` | **required**, `select: false` | ΓÇö | bcrypt hash ΓÇö **never returned in responses** |
| `role` | `String` | **required**, enum: `employee` \| `manager` \| `admin` | ΓÇö | Determines permissions |
| `department` | `String` | **required**, trimmed | ΓÇö | Organizational department |
| `managerId` | `ObjectId` | ref: `User`, optional | `null` | Direct manager reference |
| `isActive` | `Boolean` | ΓÇö | `true` | Soft-disable without deletion |
| `quotas` | `Object` | nested sub-document | see below | Leave quota balances |
| `quotas.casual` | `{ total: Number, used: Number }` | ΓÇö | `{ total: 10, used: 0 }` | Casual leave quota |
| `quotas.sick` | `{ total: Number, used: Number }` | ΓÇö | `{ total: 8, used: 0 }` | Sick leave quota |
| `quotas.annual` | `{ total: Number, used: Number }` | ΓÇö | `{ total: 14, used: 0 }` | Annual leave quota |
| `quotas.wfh` | `{ total: Number, used: Number }` | ΓÇö | `{ total: 12, used: 0 }` | Work-from-home quota |
| `createdAt` | `Date` | auto (timestamps) | ΓÇö | |
| `updatedAt` | `Date` | auto (timestamps) | ΓÇö | |

**Indexes:**

| Index | Type | Fields |
|---|---|---|
| Email unique | Unique | `{ email: 1 }` |

**JSON Transform:**

- `toJSON` transform removes `passwordHash` and `__v`, maps `_id` ΓåÆ `id`.

---

## 2. LeaveRequest

**Collection:** `leaverequests`

| Field | Type | Constraints | Default | Notes |
|---|---|---|---|---|
| `_id` | `ObjectId` | auto | ΓÇö | Primary key |
| `userId` | `ObjectId` | **required**, ref: `User` | ΓÇö | The employee requesting leave |
| `type` | `String` | **required**, enum: `casual` \| `sick` \| `annual` \| `wfh` | ΓÇö | Leave category |
| `startDate` | `Date` | **required** | ΓÇö | Inclusive start |
| `endDate` | `Date` | **required** | ΓÇö | Inclusive end |
| `days` | `Number` | **required**, min: `1` | ΓÇö | Count of weekdays between start & end (auto-computed on creation) |
| `reason` | `String` | **required**, trimmed | ΓÇö | Justification text |
| `status` | `String` | enum: `pending` \| `approved` \| `rejected` \| `cancelled` | `pending` | Current workflow state |
| `reviewedBy` | `ObjectId` | ref: `User` | `null` | Manager/admin who reviewed |
| `reviewedAt` | `Date` | ΓÇö | `null` | Timestamp of review |
| `reviewNote` | `String` | trimmed | `""` | Optional reviewer comment |
| `createdAt` | `Date` | auto (timestamps) | ΓÇö | |
| `updatedAt` | `Date` | auto (timestamps) | ΓÇö | |

**Indexes:**

| Index | Type | Fields |
|---|---|---|
| User + Status | Compound | `{ userId: 1, status: 1 }` |

---

## 3. Asset

**Collection:** `assets`

| Field | Type | Constraints | Default | Notes |
|---|---|---|---|---|
| `_id` | `ObjectId` | auto | ΓÇö | Primary key |
| `name` | `String` | **required**, trimmed | ΓÇö | Asset display name |
| `kind` | `String` | **required**, enum: `hardware` \| `software` | ΓÇö | Asset category |
| `serialNumber` | `String` | **unique** (sparse), trimmed | ΓÇö | Manufacturer serial; sparse allows multiple nulls |
| `status` | `String` | enum: `in_use` \| `available` \| `in_repair` | `available` | Current lifecycle state |
| `assignedTo` | `ObjectId` | ref: `User` | `null` | Employee currently holding the asset |
| `purchaseDate` | `Date` | optional | `null` | When the asset was procured |
| `createdAt` | `Date` | auto (timestamps) | ΓÇö | |
| `updatedAt` | `Date` | auto (timestamps) | ΓÇö | |

**Indexes:**

| Index | Type | Fields |
|---|---|---|
| Text search | Text | `{ name: "text", serialNumber: "text" }` |
| Serial unique sparse | Unique (sparse) | `{ serialNumber: 1 }` |

---

## 4. InventoryItem

**Collection:** `inventoryitems`

| Field | Type | Constraints | Default | Notes |
|---|---|---|---|---|
| `_id` | `ObjectId` | auto | ΓÇö | Primary key |
| `name` | `String` | **required**, **unique**, trimmed | ΓÇö | Item display name |
| `category` | `String` | **required**, trimmed | ΓÇö | Grouping category |
| `quantity` | `Number` | **required**, min: `0` | ΓÇö | Current stock count |
| `threshold` | `Number` | **required**, min: `0` | ΓÇö | Low-stock alert threshold |
| `unit` | `String` | **required**, trimmed | ΓÇö | Unit of measure (e.g. `"pcs"`, `"boxes"`) |
| `createdAt` | `Date` | auto (timestamps) | ΓÇö | |
| `updatedAt` | `Date` | auto (timestamps) | ΓÇö | |

**Virtuals:**

| Virtual | Type | Computation |
| --- | --- | --- |
| `isLowStock` | `Boolean` | `this.quantity <= this.threshold` |

**Indexes:**

| Index | Type | Fields |
| --- | --- | --- |
| Name unique | Unique | `{ name: 1 }` |

---

## API Endpoints

### Health

| Method | Path | Auth | Roles | Description |
| --- | --- | --- | --- | --- |
| `GET` | `/health` | None | Any | Server health check |

**Response `200 OK`:**

```
{   "status": "ok",   "db": "connected",   "uptime": 12345.67 }
```

---

### Auth Endpoints

`POST /api/auth/login`

Authenticate a user and receive a JWT.

| Detail | Value |
| --- | --- |
| **Auth** | None |
| **Roles** | Any |

**Request Body:**

```
{   "email": "john@example.com",   "password": "secret123" }
```

| Field | Type | Required | Validation |
| --- | --- | --- | --- |
| `email` | `string` | Γ£à | Valid email format |
| `password` | `string` | Γ£à | Non-empty |

**Response `200 OK`:**

```
{   "token": "eyJhbGciOiJIUzI1NiIs...",   "user": {     "id": "664a1b2c3d4e5f6a7b8c9d0e",     "name": "John Doe
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 401 | `UNAUTHORIZED` | Invalid email or password |
| 401 | `UNAUTHORIZED` | Account is deactivated ( `isActive: false` ) |

---

`GET /api/auth/me`

Return the currently authenticated user's profile.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Response `200 OK` :**

```
{   "user": {     "id": "664a1b2c3d4e5f6a7b8c9d0e",     "name": "John Doe",     "email": "john@example.com",
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 401 | `UNAUTHORIZED` | Missing or invalid token |

---

`POST /api/auth/change-password`

Change the authenticated user's own password.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Request Body:**

```
{   "currentPassword": "oldSecret",   "newPassword": "newSecret123" }
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `currentPassword` | `string` | Γ£à | Must match current hash |
| `newPassword` | `string` | Γ£à | Min 6 characters |

**Response `200 OK`:**

```
{   "message": "Password changed successfully" }
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | New password too short |
| 401 | `UNAUTHORIZED` | Current password is incorrect |

---

## Users Endpoints

> **All user management endpoints require `admin` role.**

`GET /api/users`

List all users with pagination and optional filters.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**Query Parameters:**

| Param | Type | Default | Description |
|---|---|---|---|
| `page` | `number` | `1` | Page number (1-based) |
| `limit` | `number` | `20` | Items per page (max 100) |
| `role` | `string` | ΓÇö | Filter by role ( `employee` \| `manager` \| `admin` ) |
| `department` | `string` | ΓÇö | Filter by exact department name |
| `search` | `string` | ΓÇö | Case-insensitive partial match on `name` or `email` |

**Response `200 OK`:**

```
{   "data": [     {       "id": "664a...",       "name": "John Doe",       "email": "john@example.com",       "
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is not an admin |

---

`POST /api/users`

Create a new user account.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**Request Body:**

```
{   "name": "Jane Smith",   "email": "jane@example.com",   "password": "initialPass123",   "role": "employee",
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `name` | `string` | Γ£à | Non-empty, trimmed |
| `email` | `string` | Γ£à | Valid email, unique |
| `password` | `string` | Γ£à | Min 6 characters (hashed before storage) |
| `role` | `string` | Γ£à | `employee` \| `manager` \| `admin` |
| `department` | `string` | Γ£à | Non-empty |
| `managerId` | `string` | Γ¥î | Valid ObjectId referencing an existing user |

**Response `201 Created`:**

```
{   "id": "664c...",   "name": "Jane Smith",   "email": "jane@example.com",   "role": "employee",   "department
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Missing or invalid fields |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 409 | `CONFLICT` | Email already exists |

---

`PATCH /api/users/:id`

Update an existing user's fields (partial update).

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | User ObjectId |

**Request Body** (all fields optional):

```
{   "name": "Jane Doe",   "role": "manager",   "department": "Sales",   "managerId": "664a...",   "isActive": f
```

| Field | Type | Validation |
|---|---|---|
| `name` | `string` | Non-empty if provided |
| `role` | `string` | `employee` \| `manager` \| `admin` |
| `department` | `string` | Non-empty if provided |
| `managerId` | `string \| null` | Valid ObjectId or `null` to remove |
| `isActive` | `boolean` | ΓÇö |

> **Note:** `email`, `password`, and `quotas` cannot be changed via this endpoint.

**Response `200 OK`:**

```
{   "id": "664c...",   "name": "Jane Doe",   "email": "jane@example.com",   "role": "manager",   "department":
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Invalid field values |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | User does not exist |

---

`POST /api/users/:id/reset-password`

Admin-initiated password reset for any user.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | Target user ObjectId |

**Request Body:**

```
{   "newPassword": "resetPass456" }
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `newPassword` | `string` | Γ£à | Min 6 characters |

**Response `200 OK`:**

```
{   "message": "Password reset successfully" }
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Password too short |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | User does not exist |

---

## Leaves Endpoints

`POST /api/leaves`

Create a new leave request. The `days` field is **auto-computed** as the count of weekdays (MonΓÇôFri) between `startDate` and `endDate` inclusive.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Request Body:**

```
{   "type": "casual",   "startDate": "2025-03-10",   "endDate": "2025-03-14",   "reason": "Family event" }
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `type` | `string` | Γ£à | `casual` \| `sick` \| `annual` \| `wfh` |
| `startDate` | `string` | Γ£à | Valid ISO date, must be today or future |
| `endDate` | `string` | Γ£à | Valid ISO date, must be ΓëÑ `startDate` |
| `reason` | `string` | Γ£à | Non-empty, trimmed |

**Business Rules:**

- `days` = count of weekdays between `startDate` and `endDate` (inclusive)
- The computed `days` must be ΓëÑ 1
- The user must have sufficient remaining balance: `quotas[type].total - quotas[type].used >= days`
- Quota is **not** deducted at creation ΓÇö only upon approval

**Response `201 Created`:**

```
{   "id": "665a...",   "userId": "664a...",   "type": "casual",   "startDate": "2025-03-10T00:00:00.000Z",   "e
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Invalid fields, endDate < startDate, zero weekdays |
| 400 | `QUOTA_EXCEEDED` | Insufficient leave balance |

---

`GET /api/leaves/mine`

List the authenticated user's own leave requests, sorted by `createdAt` descending.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Query Parameters:**

| Param | Type | Default | Description |
| --- | --- | --- | --- |
| `page` | `number` | `1` | Page number |
| `limit` | `number` | `20` | Items per page |
| `status` | `string` | ΓÇö | Filter by status |

**Response `200 OK`:**


```
{   "data": [     {       "id": "665a...",       "type": "casual",       "startDate": "2025-03-10T00:00:00.000Z
```


---

`GET /api/leaves/balance`

Return the authenticated user's current leave quota balances.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Response `200 OK`:**


```
{   "casual": { "total": 10, "used": 2, "remaining": 8 },   "sick": { "total": 8, "used": 0, "remaining": 8 },
```


---

`PATCH /api/leaves/:id/cancel`

Cancel a pending leave request. Only the request owner can cancel, and only while status is `pending`.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated (own request only) |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | LeaveRequest ObjectId |

**Response `200 OK`:**

```
{   "id": "665a...",   "status": "cancelled",   "...": "..." }
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Not the request owner |
| 400 | `VALIDATION_ERROR` | Leave is not in `pending` status |
| 404 | `NOT_FOUND` | Leave request does not exist |

---

`GET /api/leaves/team`

List leave requests for the manager's direct reports, or all requests for admins.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `manager`, `admin` |

**Query Parameters:**

| Param | Type | Default | Description |
|---|---|---|---|
| `page` | `number` | `1` | Page number |
| `limit` | `number` | `20` | Items per page |
| `status` | `string` | ΓÇö | Filter by status (e.g. `pending`) |

**Business Rules:**

- **Manager:** sees only requests from users whose `managerId` matches the caller's ID
- **Admin:** sees all leave requests

**Response `200 OK`:**

```
{   "data": [     {       "id": "665a...",       "userId": {         "id": "664a...",         "name": "John Doe
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is an `employee` |

---

`PATCH /api/leaves/:id/approve`

Approve a pending leave request. **Deducts** the `days` from the user's quota upon approval.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `manager`, `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | LeaveRequest ObjectId |

**Request Body** (optional):

```
{   "reviewNote": "Approved, enjoy your time off!" }
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `reviewNote` | `string` | Γ¥î | Max 500 characters |

**Business Rules:**

- Leave must be in `pending` status
- Sets `status` ΓåÆ `approved`, `reviewedBy` ΓåÆ caller ID, `reviewedAt` ΓåÆ now
- **Atomically increments** `user.quotas[type].used` by `days`

**Response `200 OK`:**

```
{   "id": "665a...",   "status": "approved",   "reviewedBy": "664b...",   "reviewedAt": "2025-03-21T14:00:00.00
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Leave is not in `pending` status |
| 400 | `QUOTA_EXCEEDED` | Approving would exceed the user's remaining quota |
| 403 | `FORBIDDEN` | Caller is an `employee` |
| 404 | `NOT_FOUND` | Leave request does not exist |

`PATCH /api/leaves/:id/reject`

Reject a pending leave request. No quota is deducted.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `manager` , `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | LeaveRequest ObjectId |

**Request Body** (optional):

```
{   "reviewNote": "Insufficient staffing during that period" }
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `reviewNote` | `string` | Γ¥î | Max 500 characters |

**Business Rules:**

- Leave must be in `pending` status
- Sets `status` ΓåÆ `rejected` , `reviewedBy` ΓåÆ caller ID, `reviewedAt` ΓåÆ now

**Response `200 OK` :**

```
{   "id": "665a...",   "status": "rejected",   "reviewedBy": "664b...",   "reviewedAt": "2025-03-21T14:30:00.00
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Leave is not in `pending` status |
| 403 | `FORBIDDEN` | Caller is an `employee` |
| 404 | `NOT_FOUND` | Leave request does not exist |

## Assets Endpoints

`GET /api/assets`

List assets with optional filters. Admins and managers see all assets; employees see only their own assigned assets.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Query Parameters:**

| Param | Type | Default | Description |
| --- | --- | --- | --- |
| `page` | `number` | `1` | Page number |
| `limit` | `number` | `20` | Items per page |
| `status` | `string` | ΓÇö | Filter: `in_use` \| `available` \| `in_repair` |
| `q` | `string` | ΓÇö | Text search on `name` and `serialNumber` |

**Business Rules:**

- **Admin / Manager:** returns all assets matching filters
- **Employee:** automatically filtered to `assignedTo === caller._id`

**Response `200 OK`:**

```
{   "data": [     {       "id": "666a...",       "name": "MacBook Pro 16\"",       "kind": "hardware",       "s
```

---

`GET /api/assets/mine`

List assets assigned to the authenticated user.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | Any authenticated |

**Response `200 OK`:**

```
{   "data": [     {       "id": "666a...",       "name": "MacBook Pro 16\"",       "kind": "hardware",       "s
```

---

`POST /api/assets`

Create a new asset.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**Request Body:**

```
{   "name": "Dell Monitor 27\"",   "kind": "hardware",   "serialNumber": "DL-MON-2025-001",   "purchaseDate": "
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `name` | `string` | Γ£à | Non-empty |
| `kind` | `string` | Γ£à | `hardware` \| `software` |
| `serialNumber` | `string` | Γ¥î | Unique if provided |
| `status` | `string` | Γ¥î | Default: `available` |
| `assignedTo` | `string` | Γ¥î | Valid user ObjectId |
| `purchaseDate` | `string` | Γ¥î | Valid ISO date |

**Response** `201 Created` **:** The created asset object.

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Missing or invalid fields |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 409 | `CONFLICT` | Duplicate serial number |

---

`PATCH /api/assets/:id`

Update an existing asset's fields.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | Asset ObjectId |

**Request Body** (all fields optional):

```
{   "name": "Dell UltraSharp 27\"",   "status": "in_repair" }
```

**Response** `200 OK` **:** Updated asset object.

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Asset does not exist |
| 409 | `CONFLICT` | Duplicate serial number |

---

`DELETE /api/assets/:id`

Permanently delete an asset.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | Asset ObjectId |

**Response** `200 OK` **:**

```
{   "message": "Asset deleted successfully" }
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Asset does not exist |

---

`PATCH /api/assets/:id/assign`

Assign an asset to a user. Sets `status` ΓåÆ `in_use`.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
| --- | --- | --- |
| `id` | `string` | Asset ObjectId |

**Request Body:**

```
{   "userId": "664a1b2c3d4e5f6a7b8c9d0e" }
```

| Field | Type | Required | Validation |
| --- | --- | --- | --- |
| `userId` | `string` | Γ£à | Valid ObjectId referencing an existing, active user |

**Business Rules:**

- Sets `assignedTo` ΓåÆ provided userId
- Sets `status` ΓåÆ `in_use`

**Response `200 OK`:** Updated asset object with populated `assignedTo`.

**Errors:**

| Status | Code | Condition |
| --- | --- | --- |
| 400 | `VALIDATION_ERROR` | Invalid or missing userId |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Asset or user does not exist |

---

`PATCH /api/assets/:id/unassign`

Remove assignment from an asset. Sets `status` ΓåÆ `available`.

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | Asset ObjectId |

**Business Rules:**

- Sets `assignedTo` Γåƒ `null`
- Sets `status` Γåƒ `available`

**Response `200 OK`:** Updated asset object.

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Asset does not exist |

---

## Inventory Endpoints

`GET /api/inventory`

List all inventory items. Each item includes the computed `isLowStock` virtual.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin`, `manager` |

**Query Parameters:**

| Param | Type | Default | Description |
|---|---|---|---|
| `page` | `number` | `1` | Page number |
| `limit` | `number` | `20` | Items per page |

**Response `200 OK`:**

```
{   "data": [     {       "id": "667a...",       "name": "A4 Paper",       "category": "Stationery",       "qua
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is an `employee` |

---

`POST /api/inventory`

Create a new inventory item.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**Request Body:**

```
{   "name": "Whiteboard Markers",   "category": "Stationery",   "quantity": 50,   "threshold": 10,   "unit": "p
```

| Field | Type | Required | Validation |
|---|---|---|---|
| `name` | `string` | Γ£à | Unique, non-empty |
| `category` | `string` | Γ£à | Non-empty |
| `quantity` | `number` | Γ£à | Integer, ΓëÑ 0 |
| `threshold` | `number` | Γ£à | Integer, ΓëÑ 0 |
| `unit` | `string` | Γ£à | Non-empty |

**Response** `201 Created` **:** The created inventory item (with `isLowStock`).

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 400 | `VALIDATION_ERROR` | Missing or invalid fields |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 409 | `CONFLICT` | Item name already exists |

---

`PATCH /api/inventory/:id`

Update an existing inventory item's fields.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | InventoryItem ObjectId |

**Request Body** (all fields optional):

```
{   "category": "Office Supplies",   "threshold": 15 }
```

**Response** `200 OK` **:** Updated inventory item.

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Item does not exist |
| 409 | `CONFLICT` | Name already taken by another item |

---

`DELETE /api/inventory/:id`

Permanently delete an inventory item.

| Detail | Value |
|---|---|
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
|---|---|---|
| `id` | `string` | InventoryItem ObjectId |

**Response** `200 OK` **:**

```
{   "message": "Inventory item deleted successfully" }
```

**Errors:**

| Status | Code | Condition |
|---|---|---|
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Item does not exist |

---

`PATCH /api/inventory/:id/adjust`

Adjust an inventory item's quantity by a delta (positive to add stock, negative to remove).

| Detail | Value |
| --- | --- |
| **Auth** | Γ£à Bearer JWT |
| **Roles** | `admin` |

**URL Parameters:**

| Param | Type | Description |
| --- | --- | --- |
| `id` | `string` | InventoryItem ObjectId |

**Request Body:**

```
{   "delta": -5 }
```

| Field | Type | Required | Validation |
| --- | --- | --- | --- |
| `delta` | `number` | Γ£à | Integer, non-zero. Resulting quantity must remain ΓëÑ 0 |

**Business Rules:**

- Atomically increments `quantity` by `delta` using `$inc`
- If resulting quantity would be < 0, the operation is rejected

**Response** `200 OK` **:** Updated inventory item (with new `quantity` and `isLowStock`).

**Errors:**

| Status | Code | Condition |
| --- | --- | --- |
| 400 | `VALIDATION_ERROR` | Delta is zero, not a number, or would result in negative quantity |
| 403 | `FORBIDDEN` | Caller is not an admin |
| 404 | `NOT_FOUND` | Item does not exist |

---

## Endpoint Summary Table

| Method | Path | Auth | Roles | Description |
|---|---|---|---|---|
| GET | /health | Γ¥î | Any | Health check |
| POST | /api/auth/login | Γ¥î | Any | Login, receive JWT |
| GET | /api/auth/me | Γ£à | Any | Get current user profile |
| POST | /api/auth/change-password | Γ£à | Any | Change own password |
| GET | /api/users | Γ£à | Admin | List users (paginated, filterable) |
| POST | /api/users | Γ£à | Admin | Create user |
| PATCH | /api/users/:id | Γ£à | Admin | Update user |
| POST | /api/users/:id/reset-password | Γ£à | Admin | Reset user password |
| POST | /api/leaves | Γ£à | Any | Create leave request |
| GET | /api/leaves/mine | Γ£à | Any | List own leave requests |
| GET | /api/leaves/balance | Γ£à | Any | Get own quota balances |
| PATCH | /api/leaves/:id/cancel | Γ£à | Any (owner) | Cancel pending leave |
| GET | /api/leaves/team | Γ£à | Manager, Admin | List team/all leaves |
| PATCH | /api/leaves/:id/approve | Γ£à | Manager, Admin | Approve leave (deducts quota) |
| PATCH | /api/leaves/:id/reject | Γ£à | Manager, Admin | Reject leave |
| GET | /api/assets | Γ£à | Any | List assets (role-scoped) |
| GET | /api/assets/mine | Γ£à | Any | List own assigned assets |
| POST | /api/assets | Γ£à | Admin | Create asset |
| PATCH | /api/assets/:id | Γ£à | Admin | Update asset |
| DELETE | /api/assets/:id | Γ£à | Admin | Delete asset |
| PATCH | /api/assets/:id/assign | Γ£à | Admin | Assign asset to user |
| PATCH | /api/assets/:id/unassign | Γ£à | Admin | Unassign asset |
| GET | /api/inventory | Γ£à | Admin, Manager | List inventory items |
| POST | /api/inventory | Γ£à | Admin | Create inventory item |
| PATCH | /api/inventory/:id | Γ£à | Admin | Update inventory item |
| DELETE | /api/inventory/:id | Γ£à | Admin | Delete inventory item |
| PATCH | /api/inventory/:id/adjust | Γ£à | Admin | Adjust item quantity |